



NANYANG
TECHNOLOGICAL
UNIVERSITY
SINGAPORE

*Addressing Issues in Generative AI System
Design and Deployment*

Part 2-Chapter 1: Security on Generative AI and Essential

Ong Chin Ann

Lecturer

College of Computing & Data Science
(chinann.ong@ntu.edu.sg)



COPYRIGHT STATEMENT

- All course materials, including but not limited to, lecture slides, handout and recordings, are for your own educational purposes only. **All the contents of the materials are protected by copyright, trademark or other forms of proprietary rights.**
- All rights, title and interest in the materials are owned by, licensed to or controlled by the University, unless otherwise expressly stated. **The materials shall not be uploaded, reproduced, distributed, republished or transmitted in any form or by any means, in whole or in part, without written approval from the University .**
- You are also not allowed to take any photograph, film, audio record or other means of capturing images or voice of any contents during lecture(s) and/or tutorial(s)
- Appropriate action(s) will be taken against you including but not limited to disciplinary proceeding and/or legal action if you are found to have committed any of the above or infringed the University's copyright.

Part 2-Topic 1: Security on Generative AI Systems and Essential

- Is Your Organization Ready for AI?
 - AI Readiness Guideline (SIG)
 - AI Verify Framework (IMDA, SG)
- Why AI Security is Different?
 - SDLC (ISO/IEC 12207 vs AIDLC (ISO/IEC 5338)
- What are the possible AI Security Attacks
- Who is responsible for Secure AI?
- How do we get Started?

Why AI Security is Important?

According to Gartner, 60% of CIOs say AI is part of their innovation plan, yet less than half feel the organization can actually manage the AI risks. Similarly, the [World Economic Forum](#) 75% of surveyed Chief Risk Officers (CROs) from major corporations and international organizations said that the use of AI poses a reputational risk to their organization. According to our research, nearly [75% of AI systems](#) face severe quality issues.

WEF, 2023 : <https://www.weforum.org/stories/2023/07/ai-biggest-risks-how-to-manage-them/>

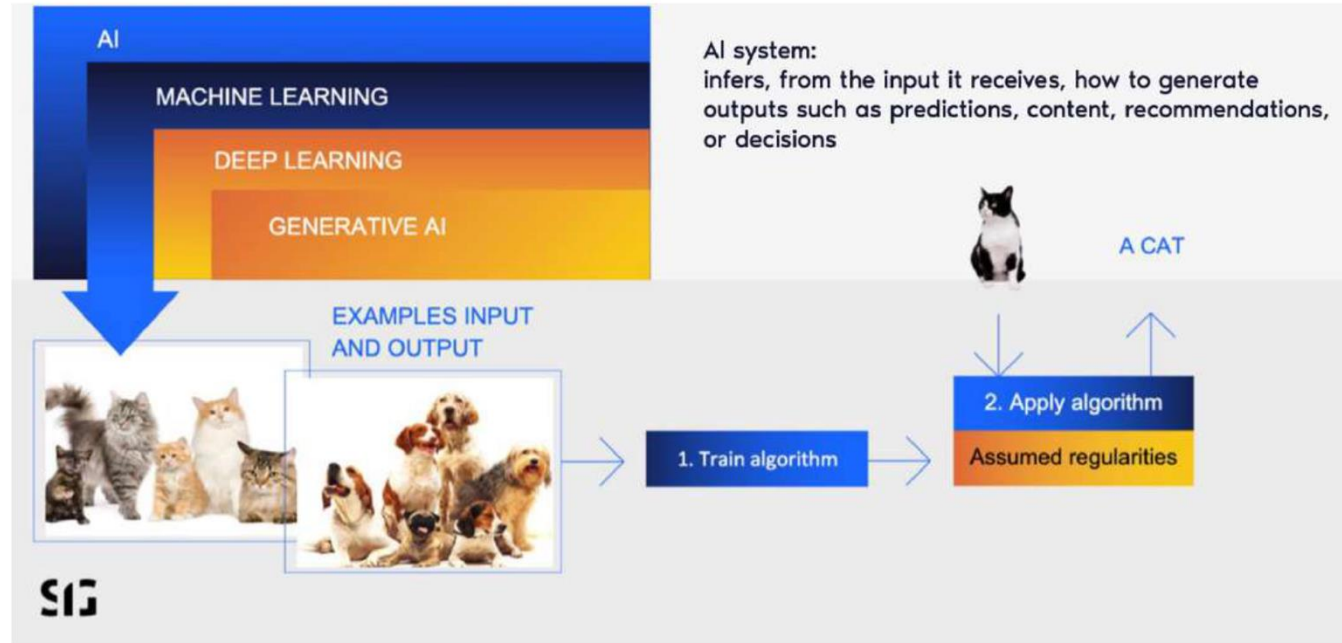


AI Readiness

IS YOUR ORGANIZATION READY FOR AI?

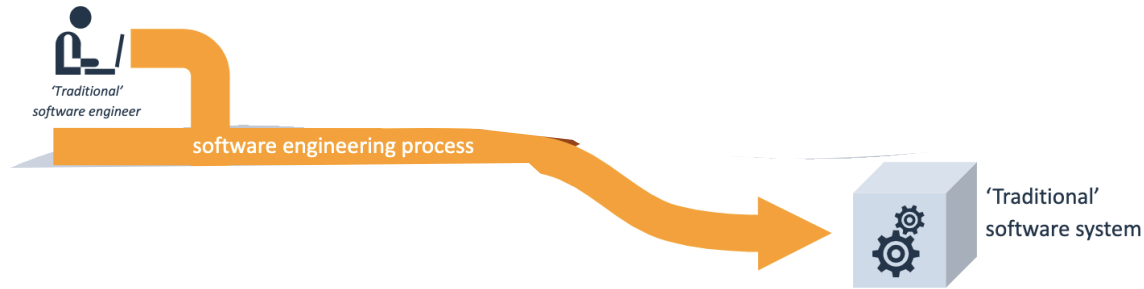


Quick Overview of AI



SIG, AI Readiness guide for organization

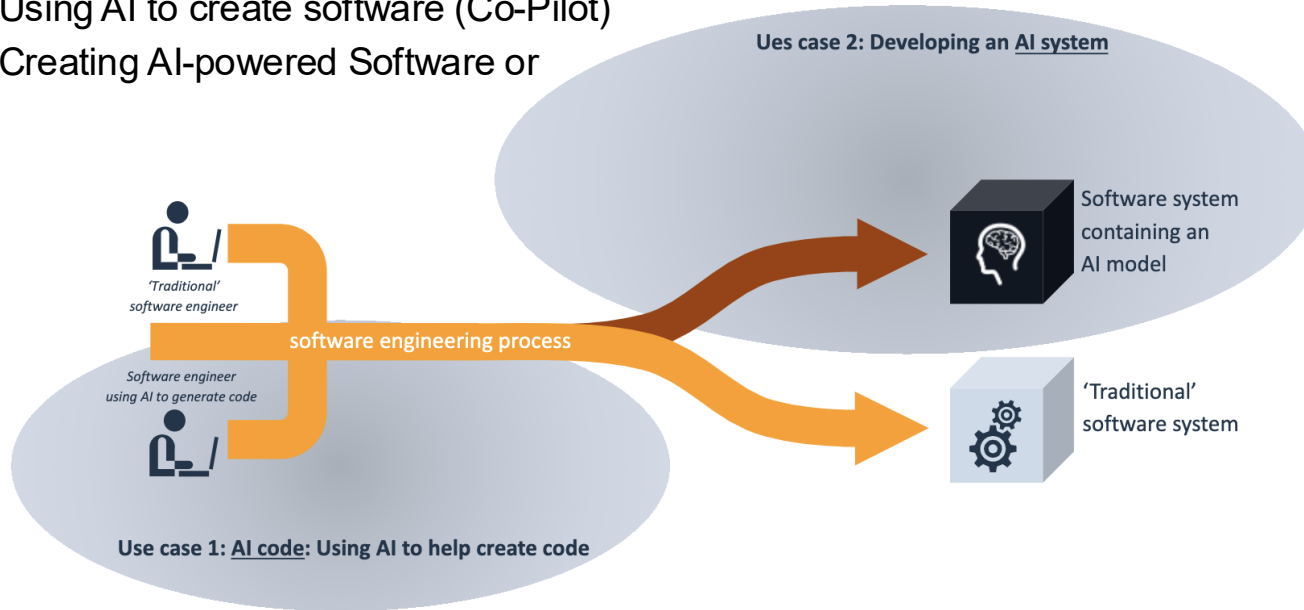
In Today's Software Engineering Context



SIG, AI Readiness guide for organization

In Today's Software Engineering Context

- UC1: Using AI to create software (Co-Pilot)
- UC2: Creating AI-powered Software or
- Both



SIG, AI Readiness guide for organization

UC1: Using AI to Create Code

- AI-supported software engineering and development with the help of GenAI tools / technologies
- Can produce faster code but can contain mistake
- Major concern
 - Code standard of quality
 - Security and vulnerability
 - Rising technical debt.

Technical debt refers to the accumulated cost of shortcuts or suboptimal design choices made during software (or AI system) development in order to deliver results quickly, which often results in increased work or risk in the future.



UC1: Using AI to Create Code

Other potential issues:

AI Makes Mistake

- Not all AI-generated code passes through human engineers, and AI makes different types of mistakes than humans do, so it requires a heightened level of scrutiny.

Looks “Perfects”

- Increased productivity from AI-generated code adds pressure on code review capacity, a common bottleneck in technical teams.

Technical Debts

- Not all issues are caught in functional tests, and unresolved issues accumulate as technical debt, slowing future development and increasing the risk of (security) incidents.

Overreliance

- Overreliance on AI can diminish an engineer's ability to review code effectively, as they may gain less hands-on experience.
- This can create a vicious cycle, but keeping engineers actively involved in the coding process can prevent this.

UC2: Developing an AI-system

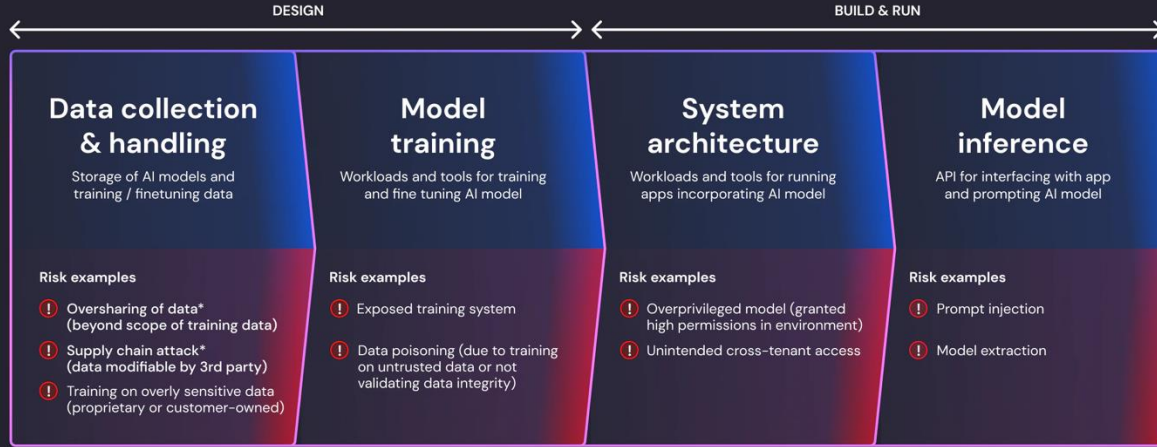
- A team building a system that employs a Gen AI/LLM model eg. chatbot.
- Significant amount of software engineering is required to make them functional (data preparation, model training, testing, and integration)
- View AI systems as software systems with unique characteristics for AI Engineering.
- This process builds on the **existing software lifecycle framework**, allowing organizations to benefit from established practices, processes, and tools.

UC2: Developing an AI-system

AI Systems characteristics and tradeoff:

- Machine learning is inductive (make prediction), not deductive
- AI behavior is driven by data, making data both a source of opportunity and risk.
- Models can go stale over time, necessitating regular retraining.
- AI can make autonomous decisions and solve real-world problems, which may have a direct impact on the world and people, with the risk of harm.
- AI is unfamiliar to many organizations and people, leading to potential implementation mistakes, under-reliance, over-reliance, or misattribution of human tendencies.
- Machine learning models can be difficult to understand, causing trust issues.
- AI introduces new technical assets that pose security threats, such as the data/model supply chain, training data, model parameters, and AI documentation.
- **Some AI systems can listen and speak:** They can communicate through natural language instead of user interfaces.
- **Some AI systems can hear and see:** They have sound and vision recognition abilities.

Security risks in the AI pipeline



<https://www.wiz.io/academy/ai-security-risks>

WIZ Research

These issue may develop and lead to the raise of

AI SECURITY, RISKS & THREATS

What is Cyber Threats?

- “Any circumstance or event with the potential to adversely impact organizational operations, organizational assets, or individuals through an information system via *unauthorized access, destruction, disclosure, modification of information, and/or denial of service*” – NIST-IR 7298
- Capable of exploiting **vulnerabilities**
- Represent potential security **harm** to an asset



Types of Threats

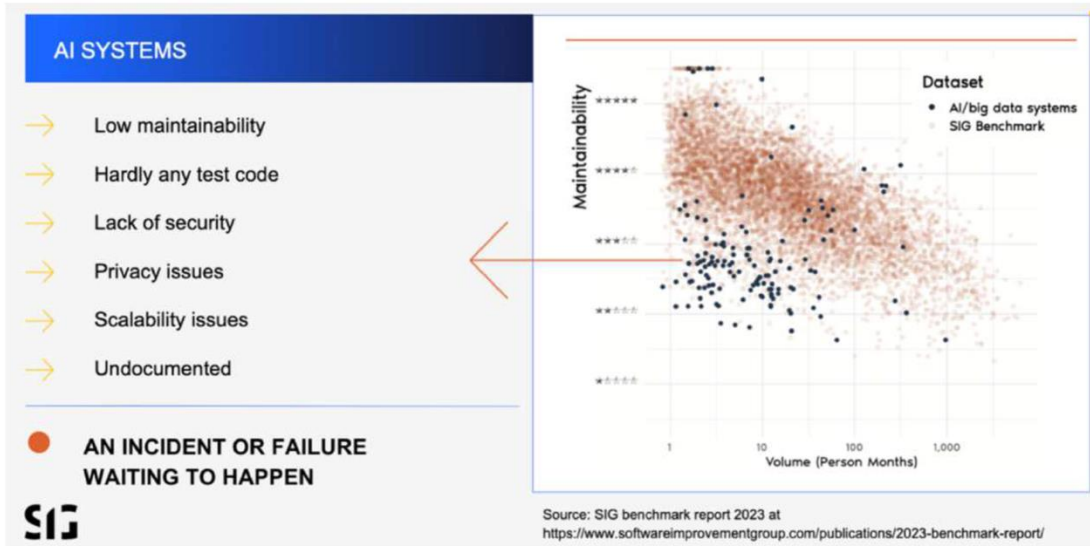
External

- Amateur / skilled attackers outside the organization
- Exploit vulnerable networks
- Gain unauthorized access to application or devices
- Social Engineering

Internal

- Employee, Contract Staff, Partners
- Mishandle data, uses infected USB drive, clicked malicious email / website links
- Poor coding practices and the lack of secure design principles

AI suffers from software engineering issues



Engineering robust, future-proof AI systems is still a relatively new field. We see many organizations struggling to transition AI from experimental projects in the lab to scalable, secure, compliant, and maintainable real-world applications. Our 2023 research revealed that **nearly 75% of AI systems** suffer from significant quality issues, particularly around maintainability.

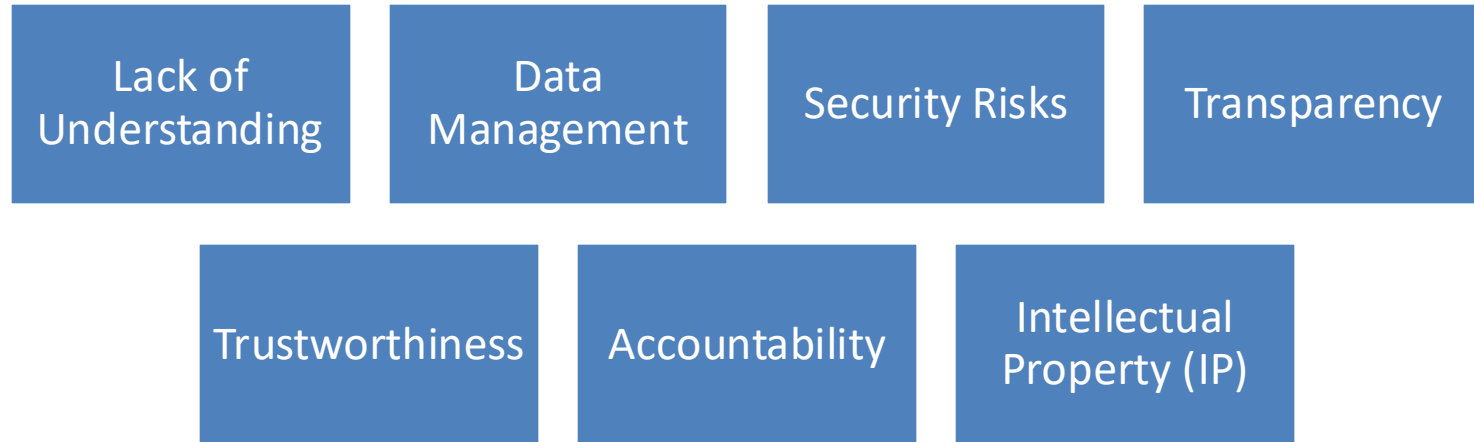
AI suffers from software engineering issues

Many AI engineers have not been introduced to essential software engineering best practices.

Building systems that may not be secure, reliable, maintainable, reusable, easy to transfer, and testable.

Other Common Threats/Security Issues of AI Development & Deployment for Organizations

while everybody is boarding the AI hype train, there is a lot to be done to ensure a safe ride.



Other Common Threats/Security Issues of AI Development & Deployment for Organizations

- A major challenge for organizations in adopting both generative AI and AI in general is the **lack of understanding** of the technology, particularly its reliance on data.
- How data is collected, stored, and used is critical.
- Without a proper understanding, organizations face **reputational, data, and security risks**.

Other Common Threats/Security Issues of AI Development & Deployment for Organizations

- The output of AI systems often directly impacts the real world and people. (**social responsibility**)
- Many AI applications lack **transparency** and **verifiability**, raising serious concerns about **trustworthiness**.
- **Accountability** is also uncertain.
 - While individuals and organizations are held liable for their mistakes under the rule of law, it's not always clear how accountability applies to AI.

Other Common Threats/Security Issues of AI Development & Deployment for Organizations

- **Intellectual Property (IP)** issues are becoming increasingly complex as AI relies heavily on data.
- AI development is **outpacing** human ability to manage its risks.
- Balancing between the **opportunities and potential risks** on AI adoption while maintaining realistic expectations. (AI Risk Management)

SDLC vs AIDLC

WHY AI SECURITY IS DIFFERENT?



AI-powered Systems / ML Applications

- involve software components (models) that allow computers to recognise and bring context to patterns in data **without** the rules having to be explicitly programmed by a human.
- generate predictions, recommendations, or decisions based on statistical reasoning



[This Photo](#) by Unknown Author is licensed under [CC BY](#)

AI-powered Systems / ML Applications

- AI systems are subject to new types of vulnerabilities.
- The term '**adversarial machine learning**' (AML), is used to describe the exploitation of fundamental vulnerabilities in ML components, including hardware, software, workflows and supply chains.



[This Photo](#) by Unknown Author is licensed under [CC BY](#)

AI-powered Systems / ML Applications

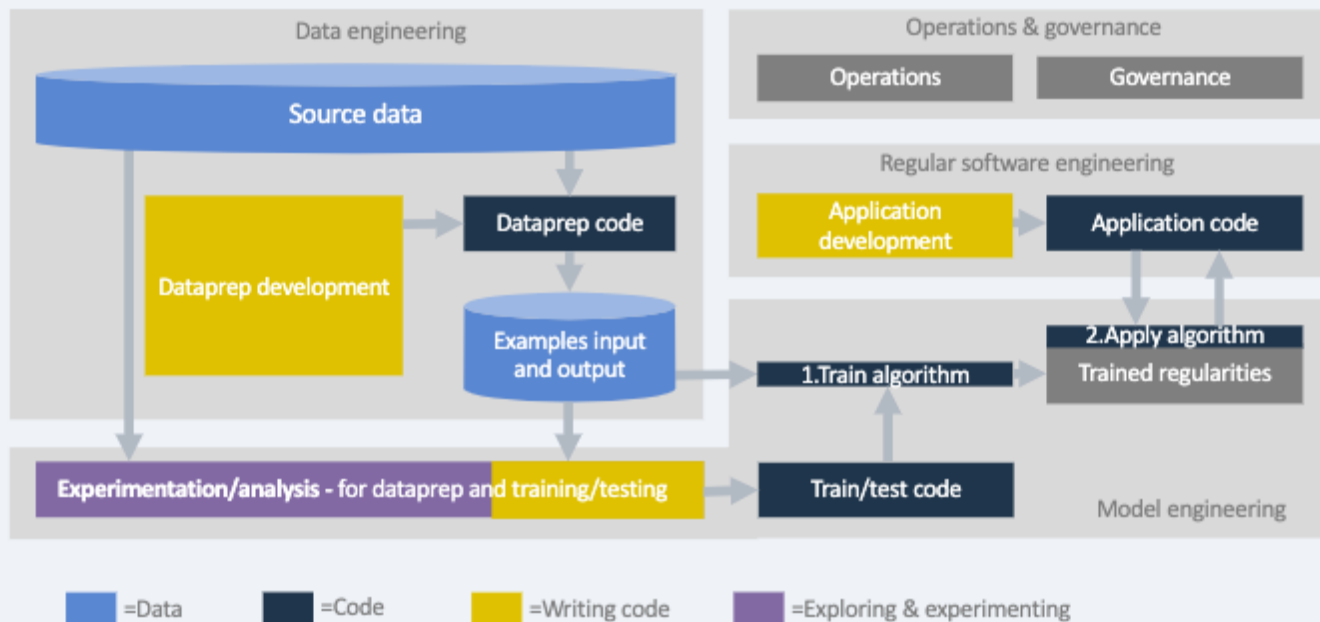
- AML enables attackers to cause unintended behaviours in AI/ML systems which includes
 - affecting the model's classification or regression performance
 - allowing users to perform unauthorised actions
 - extracting sensitive model information
- AI system compromised via common exploitations i.e. Prompt Injection Attack, Data Poisoning etc...



[This Photo](#) by Unknown Author is licensed under [CC BY](#)



AI engineering



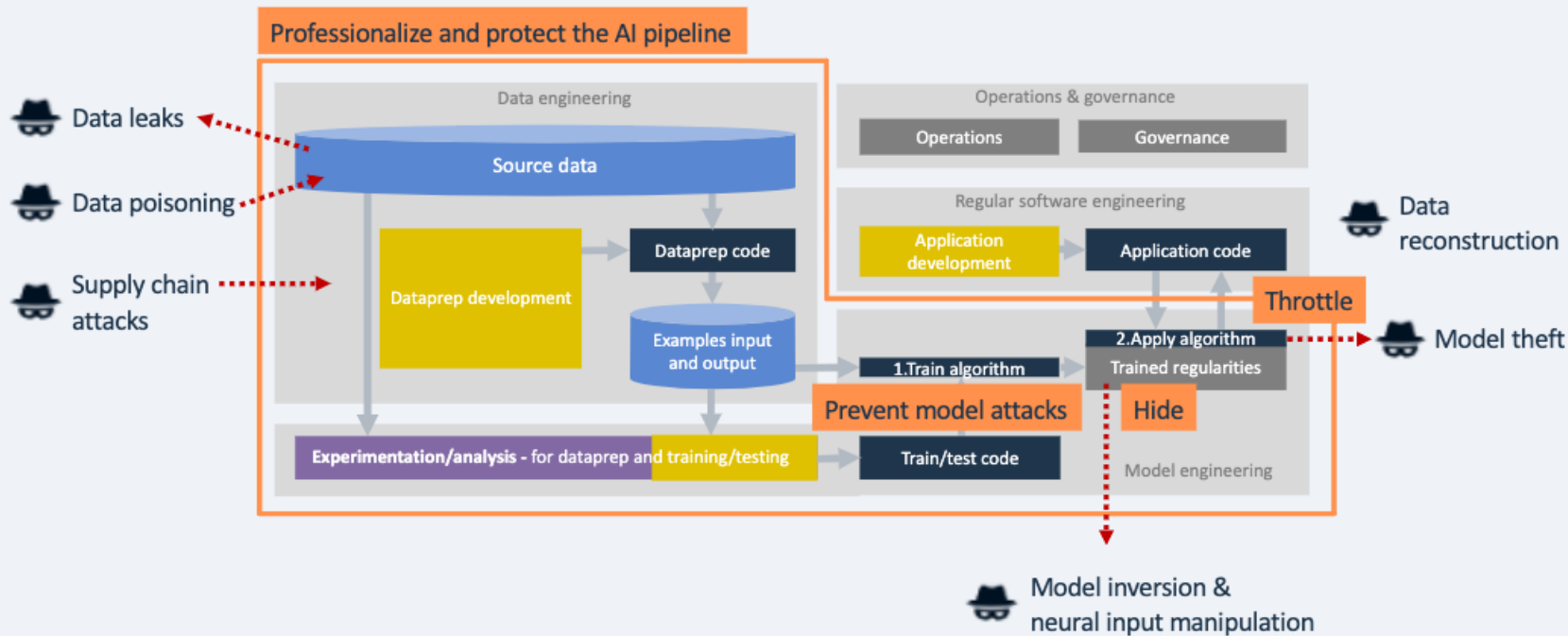
8

[OWASP Global AppSec event in Dublin, 2023](#)



// AI SECURITY

Summary AI security - threats and countermeasures



[OWASP Global AppSec event in Dublin, 2023](#)

In Short

- AI model and system development is still much more of an **art** than an exact **science**,
- developers **interact** with model code, training data, and other parameters over multiple iterations.
- Training datasets may be acquired from **unknown, untrusted sources**.
- Model weights and other training parameters can be **susceptible to malicious tampering**.
- Some models may be **complex** to the point that they cannot easily be thoroughly inspected, potentially allowing for **undetectable execution of arbitrary code**.
- User queries can be crafted to **produce undesirable or objectionable output** and — if not sanitized properly — can be leveraged for injection-style attacks.



[This Photo](#) by Unknown Author is licensed under [CC BY](#)

In Summary

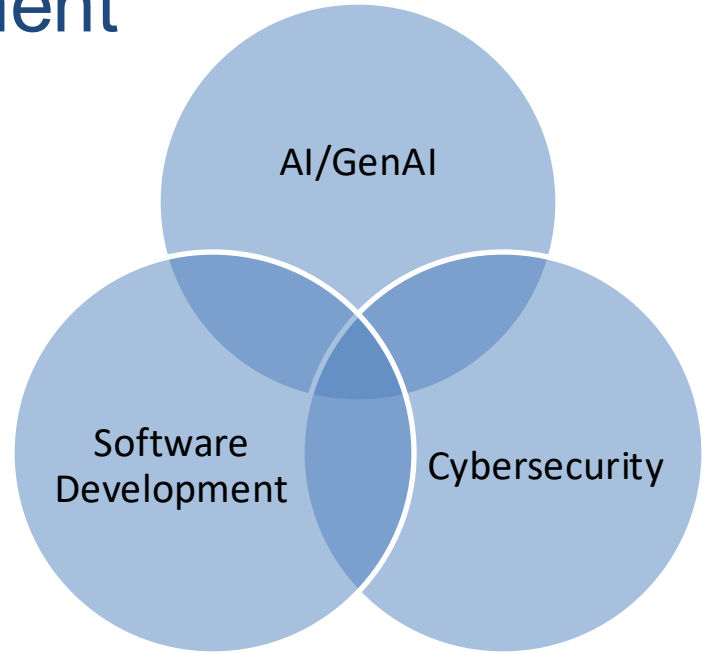
Issues & challenges when developing AI systems:

- Lack of Documentation (data collection, training, finetuning, integration...)
- Hard to automate testing
- Poor coding quality and best practices
- Development team unsure how to get started.
 - Due to lack of formal cybersecurity education
 - Lack of training and awareness
 - Lacking of support from senior management.



To Address Security Issues in Generative AI System Design and Deployment

- This course is the combination of three key domains
 - AI / GenAI
 - Cybersecurity
 - Software Development
- DevSecOps/MLOps/AISecOps
- Some principles are derived from cybersecurity / software development / software security



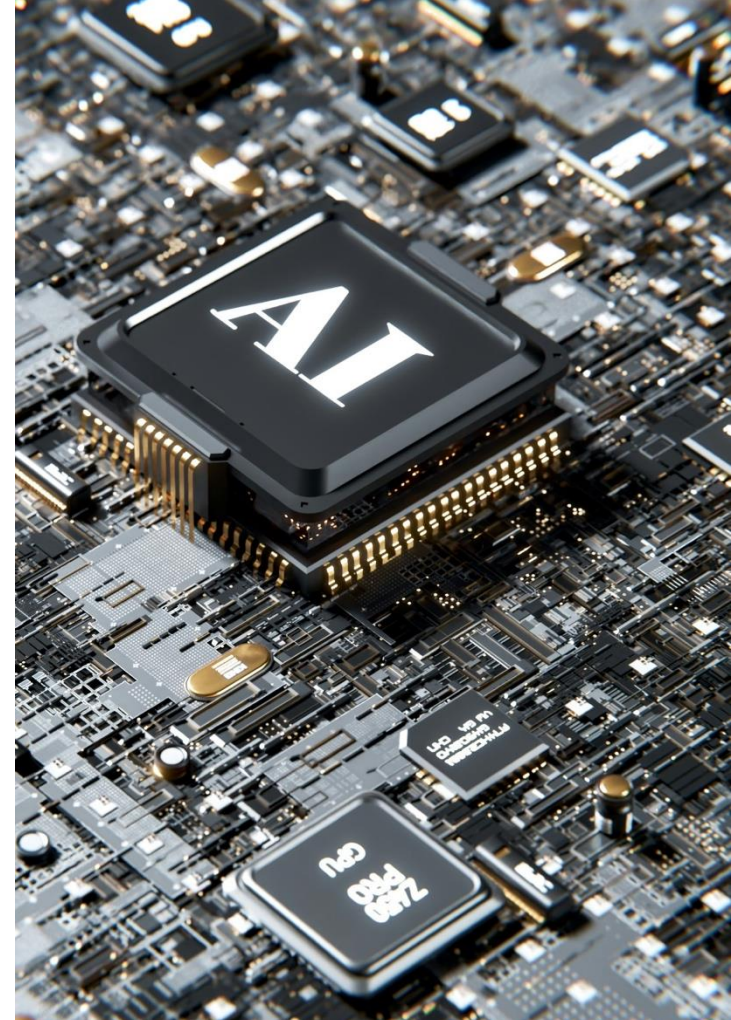
Insecure technology and vulnerabilities in systems will invite malicious cyber intrusions.

“VULNERABLE” BY DESIGN



Vulnerable by Design

- AI (GenAI) technology is integrated into nearly every facet of daily life.
- These convenience opening up various **opportunity for cyber criminals to commit cyber crimes**, which leads to major issue i.e. global cyber breaches, malicious activities, intrusion, and disruption of services.
- Negative and catastrophic impact to economic, social, and national security



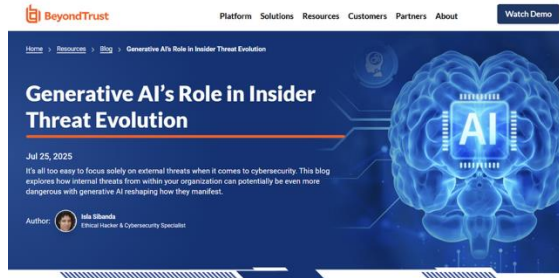
Vulnerable by Design

- Some organizations have made great strides driving the industry forward in software assurance.
- Many others still lag behind.
- Historically, software manufacturers have relied on fixing vulnerabilities found after the customers have deployed the products, requiring the customers to apply those patches at their own expense.
- Insufficient pressure and hard demand from end user / customers toward secured systems. (“Secure by Demand” culture)

Security in Generative AI Systems

WHAT ARE THE COMMON THREATS IN AI POWERED SYSTEMS?

Emerging Threats & Incidents



<https://www.beyondtrust.com/blog/entry/generative-ai-and-the-insider-threat>



<https://www.darkreading.com/remote-workforce/threat-actors-leaning-genai-tools>



https://www.trendmicro.com/en_us/research/24/1/genai-prompt-injection-attack-threat.html



<https://www.govtech.com/blogs/lohrmann-on-cybersecurity/slopsquatting-and-other-new-genai-cybersecurity-threats>



ATLAS MITRE

ATLAS Matrix

The ATLAS Matrix below shows the progression of tactics used in attacks as columns from left to right, with ML techniques belonging to each tactic below. & indicates an adaption from ATT&CK. Click on the blue links to learn more about each item, or search and view ATLAS tactics and techniques using the links at the top navigation bar. View the ATLAS matrix highlighted alongside ATT&CK Enterprise techniques on the ATLAS Navigator.

Reconnaissance ^{&} 6 techniques	Resource Development ^{&} 12 techniques	Initial Access ^{&} 6 techniques	AI Model Access ^{&} 4 techniques	Execution ^{&} 4 techniques	Persistence ^{&} 4 techniques	Privilege Escalation ^{&} 2 techniques	Defense Evasion ^{&} 3 techniques	Credential Access ^{&} 1 technique	Discovery ^{&} 7 techniques	Collection ^{&} 3 techniques	AI Attack Staging ^{&} 4 techniques	Command and Control ^{&} 1 technique	Exfiltration ^{&} 5 techniques	Impact ^{&} 7 techniques
Search Open Technical Databases ^{&}	Acquire Public AI Interfaces ^{&}	AI Supply Chain Compromise ^{&}	AI Model Inference API Access ^{&}	User Execution ^{&}	Poison Training Data ^{&}	LLM Plugin Compromise ^{&}	Evaide AI Model ^{&}	Unsecured Credentials ^{&}	Discover AI Model Ontology ^{&}	AI Adversary Collection ^{&}	Create Proxy AI Model ^{&}	Reverse Shell ^{&}	Exfiltration via AI Inference API ^{&}	Evaide AI Model ^{&}
Search Open AI Vulnerability Analyses ^{&}	Obtain Capabilities ^{&}	Vendor Accounts ^{&}	AI Enabled Product ID ^{&}	Command and Control Scripting ^{&}	Manipulate AI Model ^{&}	LLM Jailbreak ^{&}	LLM Jailbreak ^{&}		Discover AI Model Family ^{&}	Manipulate AI Model ^{&}	Manipulate AI Model ^{&}		Exfiltration via AI Inference API ^{&}	Control of AI Service ^{&}
Search Vendor-Owned Websites ^{&}	Develop Capabilities ^{&}	Evaide AI Model ^{&}	AI Service ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Output Components Manipulation ^{&}		Discover AI Model Components ^{&}	Data from Intermediate Repositories ^{&}	Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
Search Application Repositories ^{&}	Acquire Infrastructure ^{&}	Exploit Public-Facing Application ^{&}	Physical Environment Access ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Output Components Manipulation ^{&}		Discover LLM Hallucinations ^{&}	Data from Local System ^{&}	Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
Active Scanning ^{&}	Public Poisoned Datasets ^{&}	Phishing ^{&}	Full AI Model Access ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Output Components Manipulation ^{&}		Discover AI Model Outputs ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
Establish Scanning Targets ^{&}	Drive-by Compromise ^{&}			LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Injection ^{&}	LLM Prompt Output Components Manipulation ^{&}		Discover LLM Hallucinations ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
	Establish Accounts ^{&}						False RAG Entry Injection ^{&}		Discover AI Model Outputs ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
	Public Poisoned Models ^{&}						Impersonation ^{&}		Discover LLM System Information ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
	Public Hallucinated Entities ^{&}						Manipulation ^{&}		Discover LLM System Information ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
	LLM Prompt Crafting ^{&}						Compel AI Model ^{&}		Discover LLM System Information ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
	Retrieval Content Crafting ^{&}								Discover LLM System Information ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}
	Stage Capabilities ^{&}								Discover LLM System Information ^{&}		Verify Attack ^{&}		Exfiltration via AI Inference API ^{&}	Spanning AI System with Chat Data ^{&}

<https://atlas.mitre.org/matrices/ATLAS>

- Adversarial Threat Landscape for AI Systems (ATLAS)
- Navigate threats to AI systems through real-world insights
- Covers 15 Tactics with more than 100 techniques.
- Some tactics and techniques adapted from the **MITRE Adversarial Tactics, Techniques, and Common Knowledge (ATT&CK)** matrix
 - a knowledge base that details the different tactics and techniques that adversaries, or cyber attackers, use as well as the platforms they target, based on observations of real attacks that have occurred.

ATLAS MITRE

MITRE ATLAS™

Matrix Tactics Techniques Mitigations Case Studies ▾ Resources ▾

Home ▸ Matrices ▸ ATLAS Matrix

ATLAS Matrix

The ATLAS Matrix below shows the progression of tactics used in attacks as columns from left to right, with ML techniques belonging to each tactic below. & indicates an adaption from ATT&CK. Click on the blue links to learn more about each item, or search and view ATLAS tactics and techniques using the links at the top navigation bar. View the ATLAS matrix highlighted alongside ATT&CK Enterprise techniques on the [ATLAS Navigator](#).

Reconnaissance& 6 techniques	Resource Development& 12 techniques	Initial Access& 6 techniques	AI Model Access 4 techniques	Execution& 4 techniques	Persistence& 4 techniques	Privilege Escalation& 2 techniques	Defense Evasion& 8 techniques	Credential Access& 1 technique	Discovery& 7 techniques	Collection& 3 techniques	AI Attack Staging 4 techniques	Command and Control& 1 technique	Exfiltration& 5 techniques	Impact& 7 techniques
Search Open Technical Databases & Search Open AI Vulnerability Analysis Search Victim-Owned Websites & Search Application Repositories Active Scanning & Gather RAG-Indexed Targets	Acquire Public AI Artifacts Obtain Capabilities & Develop Capabilities & Acquire Infrastructure Publish Poisoned Datasets Poison Training Data Establish Accounts & Publish Poisoned Models Publish Hallucinated Entities LLM Prompt Crafting Retrieval Content Crafting Stage Capabilities &	AI Supply Chain Compromise Valid Accounts & Evade AI Model Acquire Infrastructure Phishing & Drive-by Compromise &	AI Model Inference API Access AI-Enabled Product or Service Physical Environment Access Full AI Model Access	User Execution & Command and Scripting Interpreter & LLM Prompt Injection LLM Plugin Compromise	Poison Training Data Manipulate AI Model LLM Prompt Self-Replication RAG Poisoning	LLM Plugin Compromise LLM Jailbreak	Evade AI Model LLM Jailbreak LLM Trusted Output Components Manipulation LLM Prompt Obfuscation False RAG Entry Injection Impersonation & Masquerading & Corrupt AI Model	Unsecured Credentials &	Discover AI Model Ontology Discover AI Model Family Discover AI Artifacts Discover LLM Hallucinations Discover AI Model Outputs Discover LLM System Information Cloud Service Discovery &	AI Artifact Collection Data from Information Repositories & Data from Local System &	Create Proxy AI Model Manipulate AI Model Verify Attack Craft Adversarial Data	Reverse Shell	Exfiltration via AI Inference API Exfiltration via Cyber Means Extract LLM System Prompt LLM Data Leakage LLM Response Rendering	Evade AI Model Denial of AI Service Spamming AI System with Chaff Data Erode AI Model Integrity Cost Harvesting External Harms Erode Dataset Integrity

<https://atlas.mitre.org/matrices/ATLAS>



OWASP GenAI Security Project

GETTING STARTED ▾ RESOURCES ▾ PROJECTS ▾ BLOG ABOUT ▾

IDENTIFYING AND TACKLING THE RISKS OF GEN AI SYSTEMS AND APPLICATIONS

OWASP GenAI Security Project

A global community-driven and expert led initiative to create freely available open source guidance and resources for understanding and mitigating security and safety concerns for Generative AI applications and adoption.

15k+ Members | 15+ Countries | 20+ AI Cybersecurity Publications

<https://genai.owasp.org/>

- The **OWASP Gen AI Security Project** is a global, open-source initiative dedicated to **identifying**, **mitigating**, and **documenting** security and safety risks associated with generative AI technologies, including large language models (LLMs), agentic AI systems, and AI-driven applications.
- The mission is to empower organizations, security professionals, AI practitioners, and policymakers with comprehensive, actionable guidance and tools to ensure the **secure development, deployment, and governance** of generative AI systems.

Security Attack on GenAI-powered systems



<https://genai.owasp.org/llm-top-10/>

LLM01: 2025 Prompt Injection LLM01:2025 Prompt Injection A Prompt Injection Vulnerability occurs when user prompts alter the... Read More	LLM02: 2025 Sensitive Information Disclosure LLM02:2025 Sensitive Information Disclosure Sensitive information can affect both the LLM and its application... Read More	LLM03: 2025 Supply Chain LLM03:2025 Supply Chain LLM supply chains are susceptible to various vulnerabilities, which can... Read More	LLM04: 2025 Data and Model Poisoning LLM04:2025 Data and Model Poisoning Data poisoning occurs when pre-training, fine-tuning, or embedding data is... Read More	LLM05: 2025 Improper Output Handling LLM05:2025 Improper Output Handling Improper Output Handling refers specifically to insufficient validation, sanitization, and... Read More
LLM06: 2025 Excessive Agency LLM06:2025 Excessive Agency An LLM-based system is often granted a degree of agency... Read More	LLM07: 2025 System Prompt Leakage LLM07:2025 System Prompt Leakage The system prompt leakage vulnerability in LLMs refers to the... Read More	LLM08: 2025 Vector and Embedding Weaknesses LLM08:2025 Vector and Embedding Weaknesses Vectors and embeddings vulnerabilities present significant security risks in systems... Read More	LLM09: 2025 Misinformation LLM09:2025 Misinformation Misinformation from LLMs poses a core vulnerability for applications relying... Read More	LLM10: 2025 Unbounded Consumption LLM10:2025 Unbounded Consumption Unbounded Consumption refers to the process where a Large Language... Read More

Organization, Employee, or End User

WHO IS RESPONSIBLE FOR SECURE AI DEVELOPMENT?

Modern AI Supply Chains

- Often involved many actors
 - **Provider:** responsible for data curation, algorithmic development, design, deployment and maintenance
 - **User:** provides inputs to AI systems and receives outputs generated by AI systems
- providers may look to incorporate software, data, models and/or remote services provided by **third parties** into their own systems.
- These complex supply chains make it harder for end users to understand where responsibility for secure AI lies.



Modern AI Supply Chains

- Both party typically do not have sufficient visibility and/or expertise to fully understand, evaluate or address risks associated with systems they are using.
- However, **providers** of AI components should take responsibility for the security outcomes of users further down the supply chain (**Secure by Design**)



Now, you understand common issues and risks with AI or GenAI adoption...and there are plenty of them and still growing and evolving....

HOW & WHERE TO GET STARTED?



Guidelines, Best Practices and Frameworks

Hierarchy of “Strength” (loosely):

- Guidelines → Best Practices → Frameworks → Standards → Acts

Guidelines



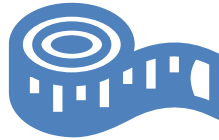
you should
consider
doing this

Best Practices



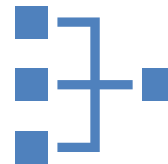
most people
in the field do
this.

Frameworks



here's how to
structure
your
approach

Standards



This is the
agreed way
to do it.

Acts



you must do
this, it's the
law

Guidelines, Best Practices and Frameworks

AI introduces new risks such as adversarial attacks, data poisoning, bias, and misuse. To address these, different layers of security governance are needed.

- **Guidelines** raise awareness and provide recommendations for safer AI adoption.
- **Best Practices** capture proven methods that practitioners can apply to protect AI systems.
- **Frameworks** give organizations a structured way to manage AI risks consistently and systematically.
- **Standards** establish a common baseline, ensuring interoperability, reliability, and trust across industries.
- **Acts** (Regulations/Laws) enforce accountability and ensure organizations take legal responsibility for secure and ethical AI use.

Together, these layers build a comprehensive ecosystem that ensures AI systems are trustworthy, safe, and secure for individuals, organizations, and society.

Common Practices and Guides

- Despite different countries are taking varied approaches to AI regulation, common themes are emerging globally.
- Establishment of EU AI Act (2024)
 - Classifies AI systems based on the risk they pose to users, with corresponding levels of regulation to ensure safety and compliance.
 - Fully applicable by 2026.
 - complements GDPR by adding specific obligations for AI systems to ensure they operate ethically and legally, especially where personal data is involved.

Transparency

Human agency
and oversight

Accountability

Technical
Robustness
and Safety

Diversity, non-
discrimination,
and fairness

Privacy and
Data
Governance

Social and
environment
well-being

<https://www.softwareimprovementgroup.com/eu-ai-act-summary/>

EU AI Act (2024) – Risk Classification

- Classified by their potential risk to individuals and society and imposes corresponding regulations to enhance safety and compliance.

Classification	Definition	Regulation
Unacceptable Risk AI Systems	Systems considered a threat to individuals, such as those manipulating vulnerable groups, engaging in social scoring, or using biometric identification and categorization.	These systems, including real-time and remote biometric identification like facial recognition, are banned, except under strict law enforcement conditions with court approval.
High-Risk AI Systems	Systems impacting safety or fundamental rights, including AI in toys, medical devices, critical infrastructure, education, employment, essential services, law enforcement, migration, and legal interpretation.	Must be registered in an EU database to ensure compliance and oversight.
Generative AI Systems	Includes AI like ChatGPT. These are not high-risk per se but must meet transparency requirements and comply with EU copyright law.	Providers of AI systems must disclose AI-generated content, prevent illegal content generation, and publish summaries of copyrighted data used for training. High-impact AI models must undergo thorough evaluations and report serious incidents to the European Commission. AI-generated or modified content (e.g., deepfakes) must be clearly labeled.

<https://www.softwareimprovementgroup.com/eu-ai-act-summary/>



Other Guides and Frameworks (High level)

Guides & Frameworks	Developed by	Remarks
Guidelines for Secure AI System Development , Nov 2023	National Cyber Security Centre (NCSC), UK	Four key areas within AI system development life cycle. Adopted by CSA, Singapore
NIST AI Risk Management Framework (AI RMF) , Jan 2023 & GAI Profile , July 2024	National Institute of Standards and Technology (NIST), US	Responsible AI Practices: Risk Framing & Addressing the Risks of AI Systems (<i>NIST AI 100-1 / NIST AI 600-1</i>)
Multilayer Framework for Good Cybersecurity Practices for AI , June 2023	European Union Agency for Cybersecurity, (ENISA)	a scalable framework to guide NCAs and AI stakeholders on the steps they need to follow to secure their AI systems, operations and processes by using existing knowledge and best practices and identifying missing elements.
Model Governance Framework for GenAI , May 2024	AI Verify Foundation, Singapore	Outlines 9 dimensions to create a trusted environment. Aims to facilitate international conversations among policymakers, industry, and the research community, to enable trusted development globally
AI readiness guide for organizations , Feb 2025	Software Improvement Group (SIG), Netherland	guide which serves as a pragmatic and actionable resource for leaders who want to get their organization ready for AI

Other Guides and Frameworks (Mid Level)

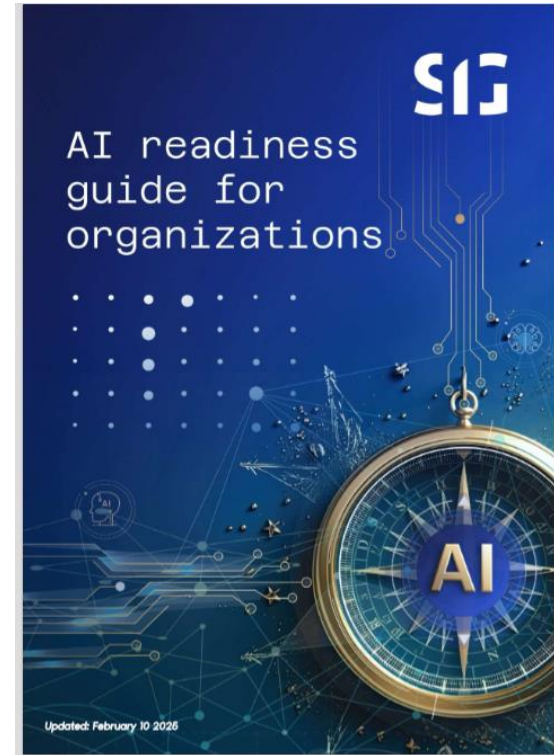
Guides & Frameworks	Developed by	Remarks
Secure by Design , April 2023.	The Cybersecurity and Infrastructure Security Agency (CISA), National Security Agency (NSA), Federal Bureau of Investigation (FBI), and various international partners including Cybersecurity Agency of Singapore (CSA)	This document intended to progress an international conversation about key priorities, investments, and decisions necessary to achieve a future where technology is safe, secure, and resilient by design and default. The authoring organization defined 3 key secure by design principles namely, Take Ownership of Customer Security Outcomes, Embrace Radical Transparency and Accountability, and Lead from the Top.
Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile , July, 2024 (NIST SP 800-218A)	National Institute of Standards and Technology (NIST), US	This document augments the secure software development practices and tasks defined in Secure Software Development Framework (SSDF) version 1.1 (NIST SP800-218) that are specific to AI model development throughout the software development life cycle.
Joint Guidance on Deploying AI Systems Securely , April 2024	National Security Agency's Artificial Intelligence Security Center (NSA AISC)	The guidance provides best practices for deploying and operating externally developed artificial intelligence (AI) systems

Other Guides and Frameworks (Low Level)

Guides & Frameworks	Developed by	Remarks
MITRE ATLAS ,	MITRE Corporation, (a U.S.-based non-profit organization that operates federally funded research and development centers to advance national security and public interest in areas like cybersecurity and defense)	ATLAS is modeled after and complementary to MITRE ATT&CK®, raising awareness of the rapidly evolving vulnerabilities of AI-enabled systems as they extend beyond cyber. Covering various exploitation tactics with detailed techniques, mitigations, as well as real world case studies.
OWASP GenAI Security Project	Open Worldwide Application Security Project (OWASP) - a nonprofit foundation that works to improve the security of software.	A global community-driven and expert led initiative to create freely available open source guidance and resources for understanding and mitigating security and safety concerns for Generative AI applications and adoption. Top 10 LLM vulnerabilities, AI Threat Intelligence and Response, Agentic App Security, Data Security, Red Teaming & Evaluation etc. GenAI Red Teaming Guide, emphasizes a holistic approach to Red Teaming in four areas: model evaluation, implementation testing, infrastructure assessment, and runtime behavior analysis.

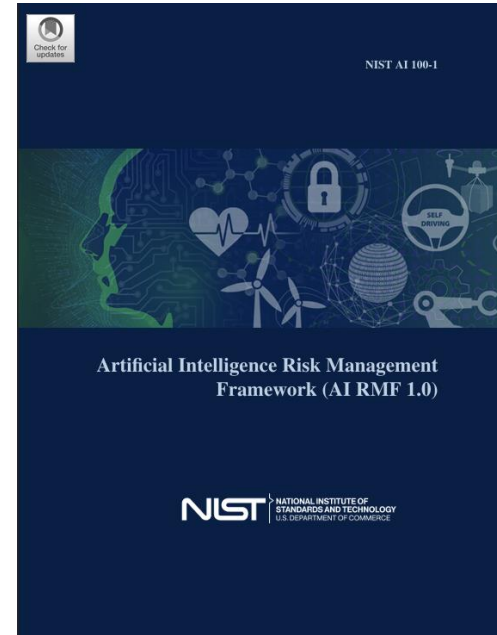
AI Readiness Guide for Organisation

- a pragmatic and actionable resource for leaders who want to get their organization ready for AI
- covering the key aspects of governance, risk management, development, and security.
- 19 steps are discussed, across four key areas of the organization, with practical recommendations tailored for roles such as the board, GRC (governance, risk, and compliance), CISO, and CTO



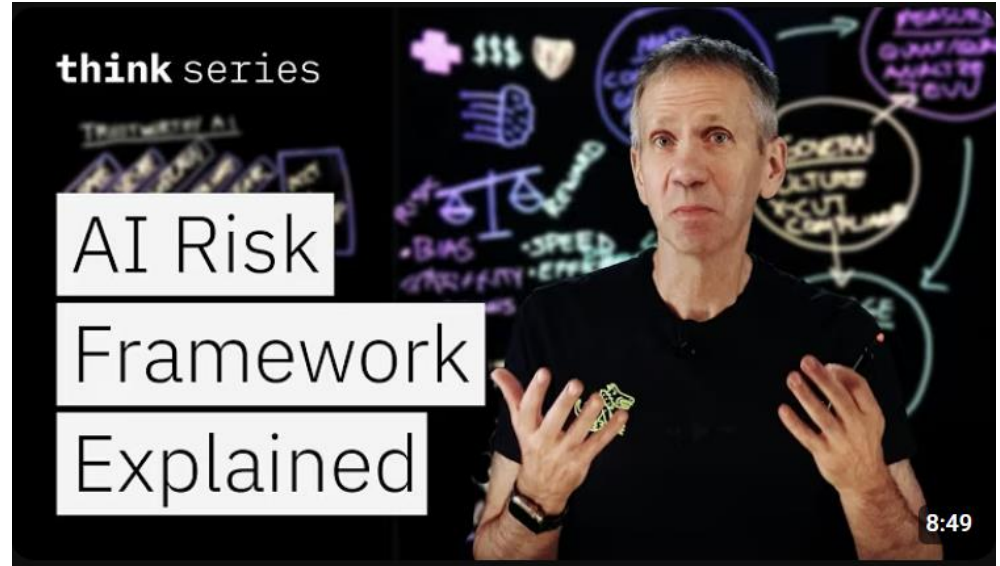
NIST AI Risk Management Framework

- **The AI RMF** refers to an AI system as an engineered or machine-based system that can, for a given set of objectives, generate outputs such as predictions, recommendations, or decisions influencing real or virtual environments.
- The framework comprises the 4 “**Core**” of the AI RMF functions, **Govern, Map, Measure, and Manage**.
- For top management and GRC
- <https://www.nist.gov/itl/ai-risk-management-framework>
- [NIST AI 600-1](#) : Extended version for GenAI Profile:



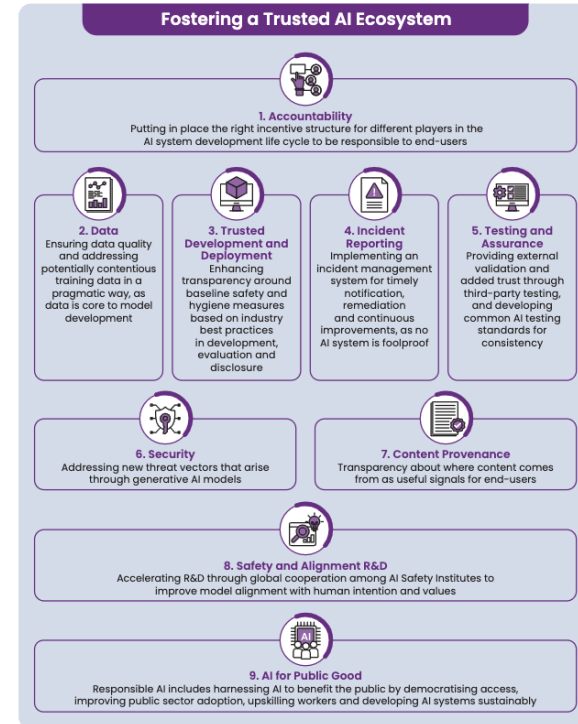
NIST AI Risk Management Framework

- General overview and introduction to AI Risk Management Framework by Jeff Crume (IBM)
- <https://youtu.be/0oeD2Wf25wY>



Model AI Governance Framework for GenAI

- Nine dimensions of the proposed Model AI Governance Framework (AI Verify Foundation, Singapore, May 2024)
- Covering wide range of elements and consideration when adopting or developing AI systems.
- For top management and GRC



Key focus for this course

NIST AI 100-1

AI RMF 1.0

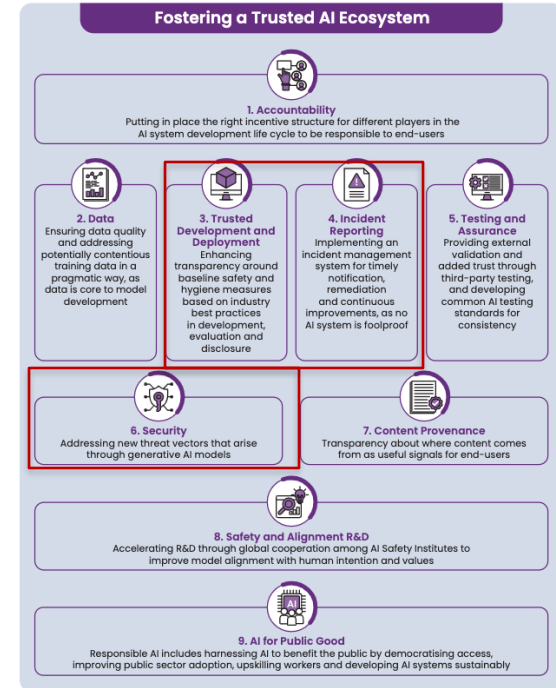
3. AI Risks and Trustworthiness

For AI systems to be trustworthy, they often need to be responsive to a multiplicity of criteria that are of value to interested parties. Approaches which enhance AI trustworthiness can reduce negative AI risks. This Framework articulates the following **characteristics** of trustworthy AI and offers guidance for addressing them. Characteristics of trustworthy AI systems include: **valid and reliable, safe, secure and resilient, accountable and transparent, explainable and interpretable, privacy-enhanced, and fair with harmful bias managed**. Creating trustworthy AI requires balancing each of these characteristics based on the AI system's context of use. While all characteristics are socio-technical system attributes, accountability and transparency also relate to the processes and activities internal to an AI system and its external setting. Neglecting these characteristics can increase the probability and magnitude of negative consequences.



Fig. 4. Characteristics of trustworthy AI systems. Valid & Reliable is a necessary condition of trustworthiness and is shown as the base for other trustworthiness characteristics. Accountable & Transparent is shown as a vertical box because it relates to all other characteristics.

NIST AI Risk Management Framework

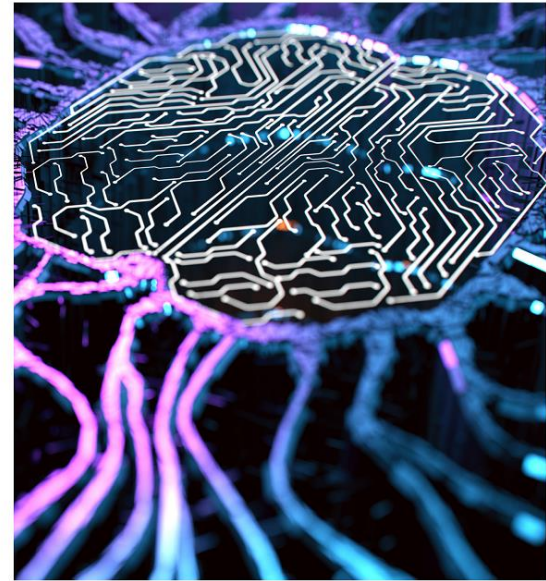


Model AI Governance Framework for GenAI

Guidelines for Secure AI System Development

- Published by the UK National Cyber Security Centre (NCSC), the US Cybersecurity and Infrastructure Security Agency (CISA), and the various international partners (including [Cyber Security Agency of Singapore](#))
- Cover key important aspects of secure design, development, deployment, and operation of AI systems
- For DevOps, MLOps, DevSecOps teams

Guidelines for secure AI system development



Secure by Design

- Published by collection of entities i.e. CISA, NSA, FBI, and various international partners including the Cybersecurity Agency of Singapore (CSA).
- The guide encourage every technology manufacturer to build their products based on reducing the burden of cybersecurity on customers.
- including preventing them from having to constantly perform monitoring, routine updates, and damage control on their systems to mitigate cyber intrusions
- Defined 3 key principles:
 - Take Ownership of Customer Security Outcomes,
 - Embrace Radical Transparency and Accountability, and
 - Lead from the Top.
- <https://www.cisa.gov/securebydesign>



Secure by Design



Secure by Design overview by Senior Technical Advisors, Bob Lord and Jack Cable from CISA.

<https://youtu.be/vkLyQcYyyTQ>



NIST 800-218 Secure Software Development Framework (SSDF) V 1.1

- Published by the National Institute of Standards and Technology (NIST), US. (Feb 2022)
- Recommendations for Mitigating the Risk of **Software Vulnerabilities**
- A core set of high-level secure software development practices that can be integrated into each SDLC implementation
- Aims to :
 - Prepare the Organization (PO)
 - Protect the Software (PS)
 - Produce Well-Secured Software (PW)
 - Respond to Vulnerabilities (RV)
- <https://csrc.nist.gov/projects/ssdf>

NIST Special Publication 800-218

Secure Software Development Framework (SSDF) Version 1.1:

*Recommendations for Mitigating
the Risk of Software Vulnerabilities*

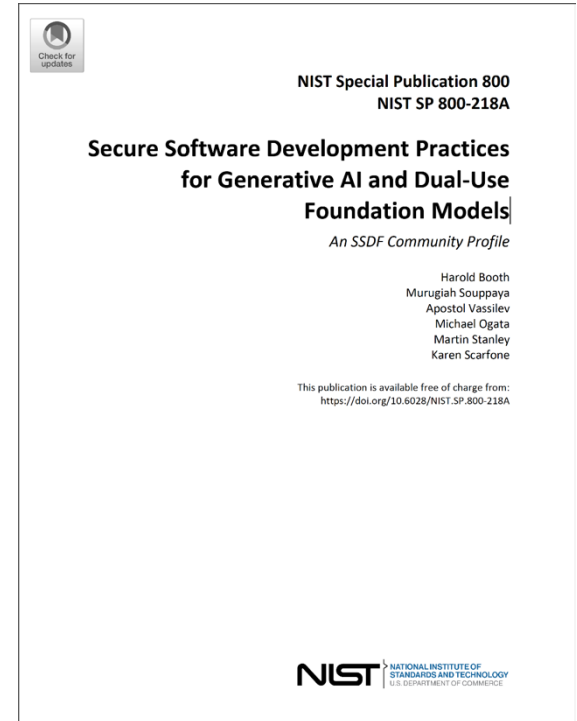
Murugiah Souppaya
Karen Scarfone
Donna Dodson

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-218>

NIST
National Institute of
Standards and Technology
U.S. Department of Commerce

NIST 800-218A Secure Software Development Practices for Generative AI and Dual-Use Foundation Models

- Augments the secure software development practices and tasks defined in Secure Software Development Framework (SSDF) version 1.1
- Adding practices, tasks, recommendations, considerations, notes, and informative references that are specific to AI model development throughout the software development life cycle.
- Intended to be useful to
 - the producers of AI models,
 - the producers of AI systems that use those models, and
 - the acquirers of those AI systems.
- <https://csrc.nist.gov/pubs/sp/800/218/a/final>



Standards - ISO/IEC

ISO42001 (Responsible AI)

- first international standard for establishing, implementing, maintaining, and improving an Artificial Intelligence Management System (AIMS)
- crucial for entities providing or utilizing AI-based products or services, ensuring **responsible AI development** and use.
- Provides a structured approach to managing AI-related risks and opportunities, balancing innovation with effective governance.

ISO23894 (AI Risk Mgmt.)

- provides guidance on how organizations that **develop, produce, deploy or use** products, systems and services that utilize artificial intelligence (AI) can **manage risk** specifically related to AI.
- aims to assist organizations to **integrate risk management** into their AI-related activities and functions.
- describes **processes** for the **effective implementation** and integration of AI risk management.

ISO27001 (Cybersecurity)

- a holistic approach to **information security**:
- helps organizations become risk-aware and proactively identify and address weaknesses
- An information security management system implemented according to this standard is a tool for risk management, cyber-resilience, and operational excellence.

ISO31700 (Privacy)

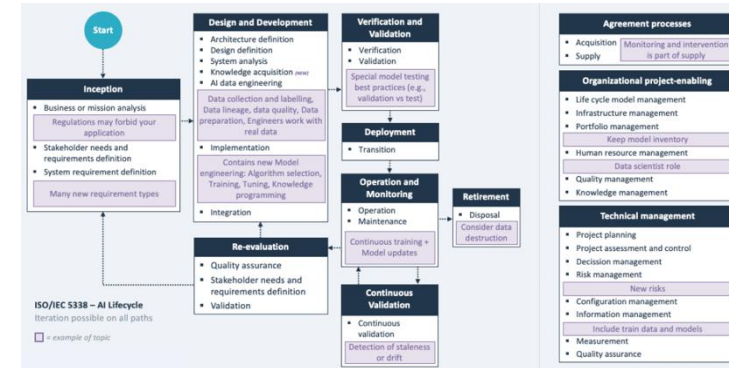
- establishing high-level requirements for **privacy by design**.
- to protect privacy throughout the lifecycle of a consumer product, including data processed by the consumer.

[Get to know the global standard on AI systems, SIG.](#)



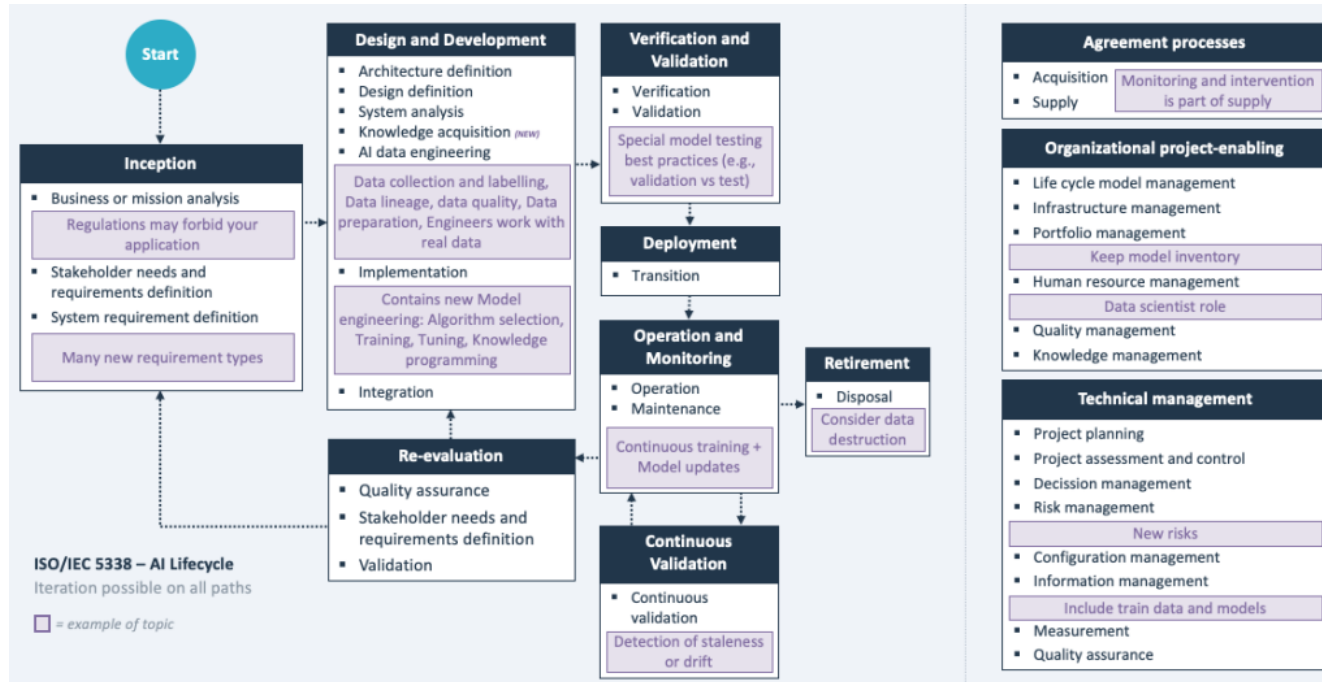
ISO/IEC 5338:2023 – AI Lifecycle

- Covers AI-specific aspects for all software lifecycle processes, following the ISO/IEC 12207 standard.
- Can be useful to obtain the ISO/IEC 12207 to get you started.
- Can use the ISO/IEC 5338 without the ISO/IEC 12207, as a checklist of attention points for AI.



[Get to know the global standard on AI systems, SIG.](#)

ISO/IEC 5338:2023 – AI Lifecycle

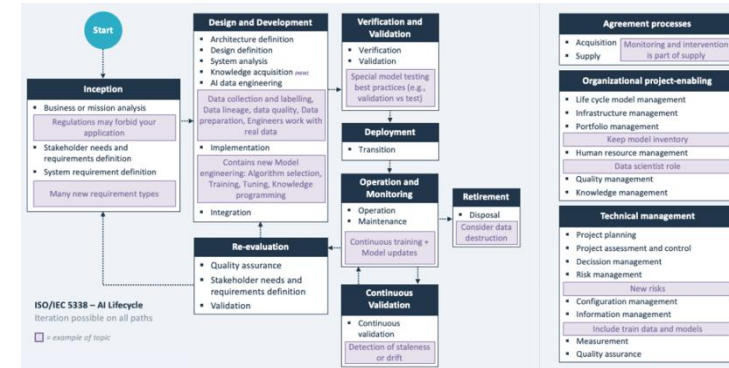


[Get to know the global standard on AI systems, SIG.](#)

ISO/IEC 5338:2023 – AI Lifecycle

Specifically focus on key AI Lifecycle

- The importance of protecting the sensitive training data that engineers work with to build a model,
- The range of new risk topics (e.g. transparency, unwanted bias, purpose-binding);
- Project managers will need to know how AI projects can be hard to predict in experimental stages;
- HR-wise it is important to know that you need different skill sets;
- When models run in production their performance can be continuously validated to detect issues and to see if the model is going 'stale'.



[Get to know the global standard on AI systems, SIG.](#)

AI – BLUEPRINT FOR LEADERSHIP



Please note that the diagram and the order of the chapters are organized for readability and do not reflect any hierarchy of importance among the departments.

<https://youtu.be/K4GRGxGYJbE>

<https://www.softwareimprovementgroup.com/ai-for-executives/>

This Course adopted the Secure AI System Development Lifecycle

NCSC Guidelines for Secure AI System Development

Secure Design

- Understanding risks and threat modelling, as well as specific topics and trade-offs to consider on system and model design.

Secure Development

- AI system development lifecycle, including supply chain security, documentation, and asset and technical debt management.

Secure Deployment

- AI system development life cycle, including protecting infrastructure and models from compromise, threat or loss, developing incident management processes, and responsible release.

Secure Operation and Maintenance

- Relevant actions once a system has been deployed, including logging and monitoring, update management and information sharing.

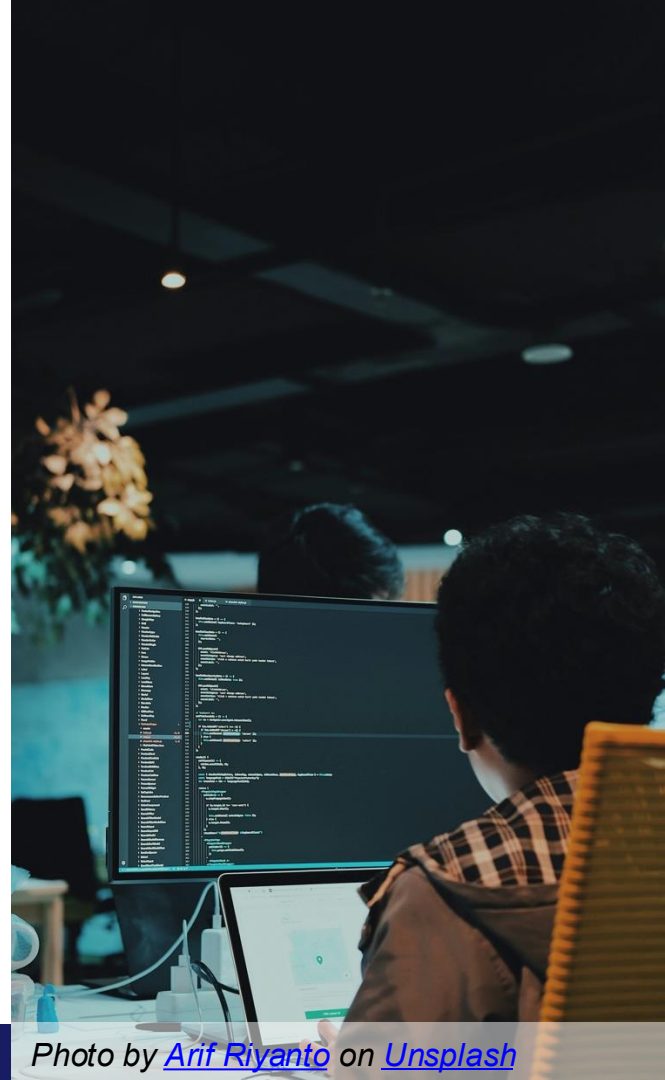
Secure Design Principles

- Raise staff awareness of threats and risks
- Model the threats to your system
- Design your system for security as well as functionality and performance
- Consider security benefits and trade-offs when selecting your AI model



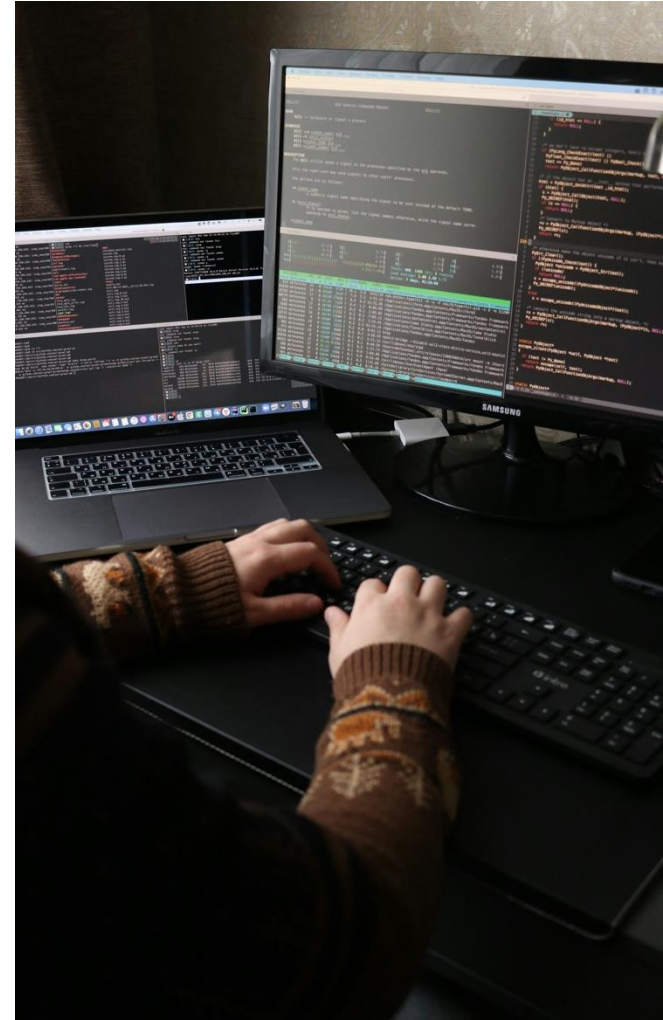
Secure Development

- Secure your supply chain
- Identify, track, and protect your assets
- Document your data, models, and prompts
- Manage your technical debt



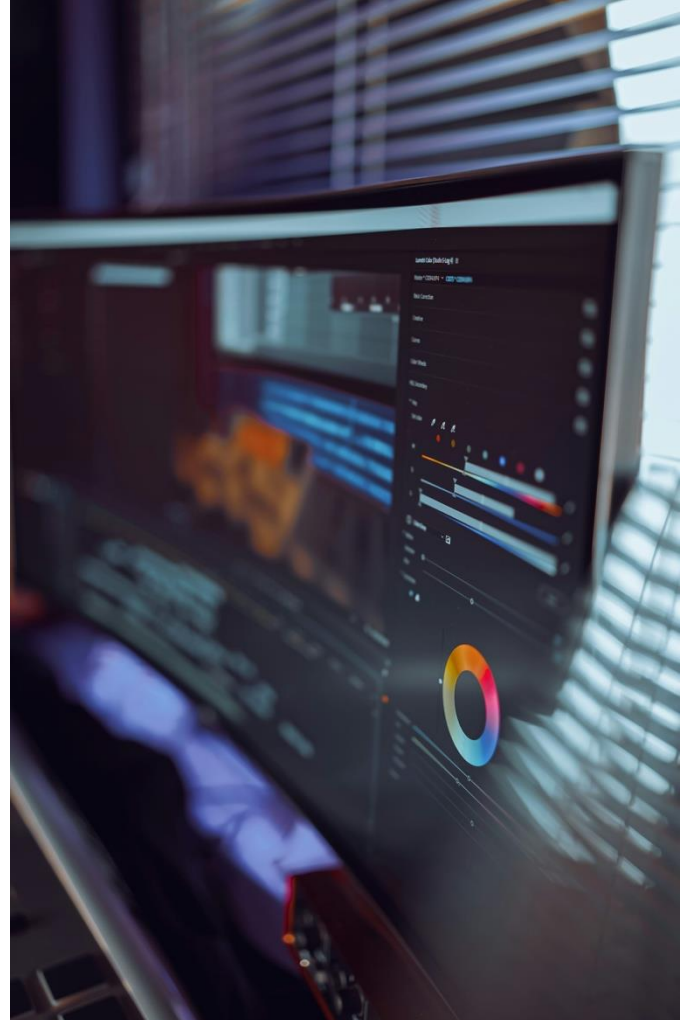
Secure Deployment

- Secure your infrastructure
- Protect your model continuously
- Develop incident management procedures
- Release AI responsibly
- Make it easy for users to do the right things



Secure Operation and Maintenance

- Monitor system's behaviour
- Monitor system's input
- Follow a secure by design approach to updates
- Collect and share lesson learned



References

- NCSC Guidelines for Secure AI System Development
- SIG, AI readiness guide for organization
<https://www.softwareimprovementgroup.com/wp-content/uploads/ai-readiness-guide-download.pdf>

Guidelines for secure AI system development

